Topic 10

BUG BOUNTY PROGRAMS AND ETHICAL HACKING



Danial Hariz

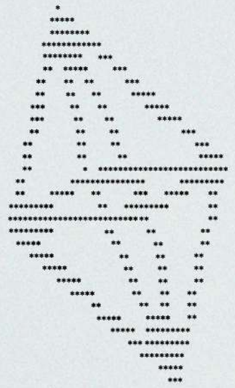
Cerberix



Introduction

Bug bounty programs and ethical hacking represent an emerging trend in cybersecurity, where organizations collaborate with ethical (white-hat) hackers who are authorized to simulate cyberattacks in order to identify and fix vulnerabilities before malicious actors can exploit them. Through bug bounty programs, companies offer financial rewards to a global community of security researchers for responsibly reporting weaknesses in their systems, applications, or networks. This approach addresses the growing complexity and sophistication of cyber threats—where traditional in-house defenses often fall short and data breaches continue to cost organizations millions annually—by crowdsourcing diverse expertise from thousands of skilled individuals worldwide to strengthen overall security posture.

Cobalt Pentest as a Service (PTaaS)





Cobalt (formerly CrowdCurity), was founded in 2013 which provides on-demand Penetration Testing delivered through a digital platform. They are the pioneers of this category. Before them, pentesting was a consulting service, after them, it became a software platform.
Unlike tradiotional firms that send you a PDF report weeks later, Cobalt uses a Software as a Service (SaaS) platform to conenct you with top-tier pentesters immediately, offering real-time results and integration with developer tools (Jira, Github).

- **2013** Founded (originally as CrowdCurity) by visionaries wanting to modernize security testing.
- **2016** Officially launched the Pentest as a Service (PTaaS) model.
- **2022** Named a "Leader" and "Outperformer" in the GigaOm Radar for PTaaS for three consecutive years.
- **2025** Launched Hybrid Pentesting (combining Human expertise + AI automation).

How Cobalt Operates

Cobalt, like any other PenTest company use almost the same methodology like any other PenTesting methodologies out there. For example, the most famous methodology are OWASP's.

The different is, Cobalt will launch a full penetration test in as little as 24 hours, eliminating the traditional 4-week waiting period for consultant availibity. They also will connect you directly with pentesters via their SaaS platform or Slack integration to clarify bugs instantly, rather than waiting for a static PDF report.



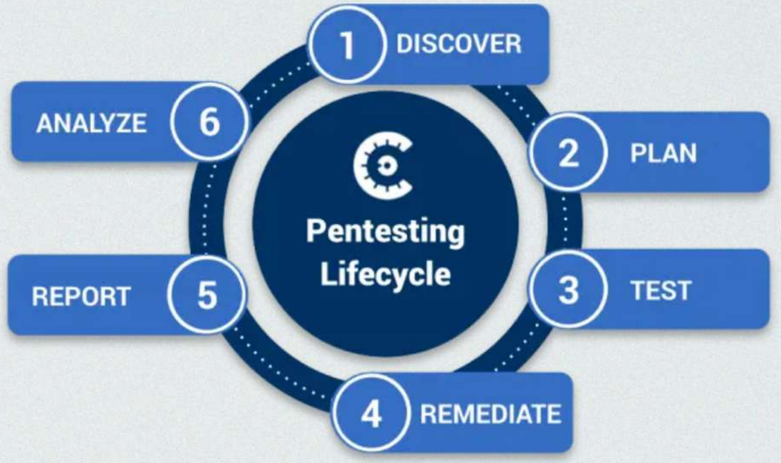


Figure A : Cobalt's PenTest Methodology

The Ethical Hacking "Kill Chain"

1) Reconnaissance: The hacker scans the company to find open doors (ports, subdomains).

2) Scanning & Enumeration: They identify outdated software or weak configurations.

3) Exploitation: They attempt to bypass security (e.g., using SQL Injection or Cross-Site Scripting) to prove they could steal data.

4) Reporting: Instead of stealing data, they write a report on how to fix the hole.

Outcome

- . **Accelerated Remediation**

"Fix vulnerabilities 50% faster than traditional methods because developers can validate fixes in real-time with the tester."

- **Continuous Risk Reduction**

"Shift from 'snapshot' security (testing once a year) to continuous testing that aligns with your agile software release cycles."

- **Reduced Overhead**

"Cut project management time by 62% by replacing email chains and spreadsheets with a centralized dashboard that tracks every finding."

- **Audit-Ready Compliance**

"Instantly generate exportable reports for SOC 2, ISO 27001, and PCI-DSS, ensuring you are always ready for auditor requests."





Apple Bug Bounty Program

Apple's Security Bounty program is a flagship initiative in the bug bounty landscape, designed to incentivize ethical hackers and security researchers to identify vulnerabilities in Apple's ecosystem before they can be exploited by malicious actors. Launched as an invitation-only program in 2016 and expanded to the public in 2020, it rewards discoveries across iOS, iPadOS, macOS, watchOS, tvOS, visionOS, and related services like iCloud and Private Cloud Compute (PCC).

- **2016** Apple started an enclusive bug bounty program that offer up to 200,000 dollar in critical finds
- **2019** Started to expand publicly with increasing reward until 1 million dollars
- **2020** Fully launced the program
- **2025** The program is now widely considered one of the best and most lucrative bug bounty programs in the world

How Apple Operates

Researchers submit vulnerabilities through Apple's dedicated portal, providing detailed reports with proof-of-concept (PoC) exploits. Submissions must adhere to guidelines: issues on the latest public software/hardware qualify, and rewards are based on severity, exploitability, and real-world impact. Apple reviews reports via its Security Engineering and Architecture (SEAR) team, validates findings, and issues fixes before public disclosure, often assigning CVEs and crediting researchers.

Scope of the reports
i. Core OS components
ii. Apps
iii. Services
iv. Hardware

October of 2025

Target Flags were introduced as a new mechanisms for security researchers.

1) Allow objective demonstration of exploitability for high priority bounty categories
- Remote Code Execution (RCE)
- Transparency, Consent, and Control (TCC) bypasses

2) Help determine eligibility for specific reward tiers
- Qualify for accelerated award processing
- Rewards issued immediately after verification even before a fix is released

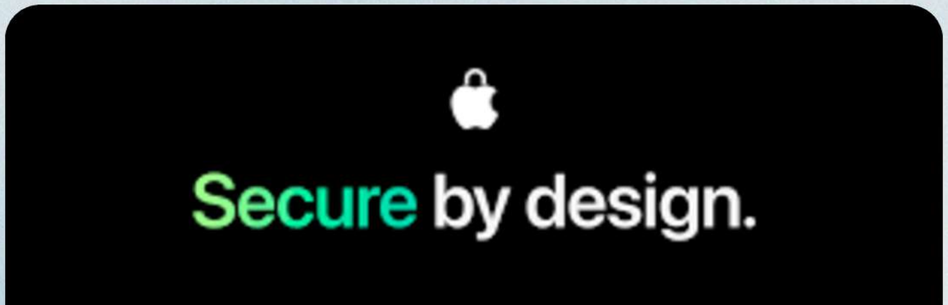
Outcome

Notable Early Case (Sam Curry & Team):

- Identified 55 vulnerabilities across Apple services in just 3 months
- Included 11 critical issues, such as:
  - Remote Code Execution via authorization bypasses and command injection
  - Wormable iCloud vulnerabilities capable of spreading via email
  - Theft of photos, videos, documents, and other user data
  - Brute-force access to an Apple Distinguished Educator admin account
- Apple patched the issues rapidly and awarded a substantial bounty

Recent Examples:

- WebKit sandbox escapes and TCC bypasses on macOS
  - Contributed to stronger privacy and security hardening
- 2025 Stored XSS vulnerability on developer.apple.com and related domains
  - Allowed arbitrary JavaScript execution on sensitive Apple web assets
  - Reported by Youssef Desouki (Zombie Hack)
  - Earned a $5,000 bounty after validation and remediation



Who is affected?

- Organizations/Companies: Financial loss, reputation damage, and regulatory fines.
- Individuals/Customers: Identity theft, loss of private photos/data (e.g., the iCloud vulnerability mentioned in Slide 7), and financial fraud.
- Governments & Critical Infrastructure: National security risks if software used in public services or defense is compromised.

Why is it considered a current problem? (Tradtional Defense Fall)

- Speed of Development: Modern software updates too fast for traditional security checks to catch up (Agile/DevOps).
- Zero-Day Vulnerabilities: Hackers are finding flaws that no antivirus knows about yet; only human hackers can find these logic errors.
- AI-Powered Attacks: Malicious actors are using AI to attack faster, so companies need "friendly" hackers to defend just as fast.

Impact on Organization

For a big organization or major company that are holding a lot of user's or sensitive information and data. Shifting from a "closed doors" policy to an open bug bounty program and pentesting is a major strategic move.

Because, the cost effectiveness of paying a $2,000 bounty for a bug or $6,850/year for pentest is significantly cheaper than millions lost in a data breach, legal fees, and regulatory fines.





Prevention and Mitigation

1. Define Clear Scope and Rules: Clearly define what is in-scope of the program, what types of vulnerabilities are in-scope, and safe harbor policies to protect hackers from legal issues.

2. Assign a Dedicated Team: Assign a dedicated team to handle the reports in a timely manner, with a goal of responding to each report in under 48 hours.

3. Offer Competitive Bounties: Offer bounties in a tiered table format according to severity levels. Offer bounties on triage to reward loyalty.

4. Promote Quality Reports: Require hackers to provide a PoC, impact descriptions, and reproduction steps to increase the quality of reports.

5. Integrate with Existing Security Processes: Integrate with internal ethical hacking teams to perform hybrid testing.

6. Utilize Bounty Platforms: Work with Bounty Platforms such as HackerOne to make the process more streamlined.





Conclusion

Ethical Hacking and Bug Bounty is a crucial discipline in the field of cybersecurity. By leveraging ethical hacking methodologies, individuals and organizations can identify and address vulnerabilities, strengthen their defenses, and protect sensitive information from malicious threats.

